LEZIONE 05

Phishing, e tutti i canali da cui arriva

Quasi tutti gli attacchi cominciano con un messaggio. Non è detto che sia una mail.

A COLPO D'OCCHIO

Email

Phishing di massa, oppure mirato su una persona.

«Il suo account è bloccato»

Telefono

Vishing: una voce calma e un problema urgente.

«Mi detti il codice»

SMS

Smishing: un collegamento da toccare.

«Pacco in giacenza»

Codice QR

Quishing: porta a una pagina di accesso falsa.

«Inquadra per pagare»

Perché l'attacco punta alle persone

Chi clicca su un link sbagliato non è l'anello debole: è la vittima di una truffa costruita appositamente. Le leve sono sempre le stesse: **l'autorità** ("sono l'IT, sono il capo"), **l'urgenza** ("entro oggi o..."), **la paura** ("il tuo account è bloccato"), **il buon cuore** di chi vuole aiutare, **la stanchezza** di fine giornata. Non serve bucare un sistema se si convince una persona a farlo per te.

Per questo in azienda non si dà la colpa a chi ha cliccato: chi si sente colpevole nasconde, e il primo a saperlo sarà l'attaccante. Chi avvisa subito, invece, ha fatto la cosa giusta.

Phishing e le sue varianti

- **Phishing:** invio di **messaggi/email ingannevoli** (finti fornitori, banche, colleghi) per indurre la vittima a **rivelare dati** (credenziali) o **cliccare** link/allegati malevoli. È di **massa**, mandato a molti.
- **Spear phishing:** phishing **mirato e personalizzato** verso **un individuo o un'organizzazione specifica** (usa nome, ruolo, contesto reale). Molto più credibile.
- **Whaling:** spear phishing contro **dirigenti** ("pesci grossi").

Segnali: mittente sospetto/simile ma non identico, link che non corrisponde al testo, urgenza anomala, richieste di credenziali o pagamenti.

Cambiare canale: vishing, smishing, quishing

Il social engineering non è solo email:

Nome	Canale	Esempio
Vishing	**voce / telefono**	finto operatore banca che chiede l'OTP
Smishing	**SMS**	"pacco in giacenza, clicca qui"
Quishing	**QR code**	QR che porta a un sito di login falso

Un caso vero: a Twitter è bastato il telefono

Il 15 luglio 2020 qualcuno ha messo le mani su 130 account Twitter — fra cui quelli di Obama, Musk, Gates e Biden — e da una quarantina ha lanciato una truffa in bitcoin. Non è entrato bucando un server: ha telefonato.

Gli attaccanti hanno chiamato alcuni dipendenti dell'assistenza fingendosi colleghi dell'ufficio IT, e con una scusa si sono fatti dare le credenziali degli strumenti interni. Da lì potevano scrivere dai profili di chiunque. Twitter, raccontandolo, ha parlato apertamente di persone «ingannate» e di «vulnerabilità umane» sfruttate — non di un dipendente distratto.

È il punto della lezione in un caso solo. Un'azienda con un reparto di sicurezza intero, fermata da una telefonata fatta bene. Chi ha risposto non era l'anello debole: era la vittima di una truffa studiata per ingannarlo. E la porta non è stata una mail, ma il telefono — il canale che quasi nessuno sorveglia.

Un esempio: una mail che arriva davvero

Oggetto: *Fattura in scadenza – sollecito*. Mittente: `amministrazione@fornitore-srl.com`, mentre il fornitore vero usa `fornitore.com`. Nel testo: «Le ricordiamo che la fattura allegata scade oggi. Per evitare la sospensione delle forniture la preghiamo di procedere al pagamento entro le ore 17». Allegato: un file Excel.

I segnali ci sono tutti:

- **mittente simile ma non uguale** (una lettera, un trattino, un dominio diverso);
- **urgenza** con un orario preciso;
- **minaccia** («sospensione delle forniture»);
- **allegato** che chiede di abilitare qualcosa, oppure un link che porta a una pagina di login.

Nessuno di questi segnali da solo è una prova. Insieme, sì. La domanda da far fare ai colleghi non è «è vera?» ma «me l'aspettavo?». Una fattura di un fornitore che non ha consegnato niente questo mese non ci si aspetta.

Cosa fare quando arriva

1. Non cliccare, non aprire, non rispondere.
2. Inoltrarla al canale che hai creato (un indirizzo, un gruppo, anche solo te).
3. Se serve una verifica, si chiama il fornitore al numero che si aveva già, non a quello nella mail.

E se qualcuno ha già cliccato: cambia subito la password di quell'account, attiva il secondo fattore se non c'era, controlla nelle impostazioni della casella che non siano comparse regole di inoltro verso l'esterno (è la prima cosa che fanno), e avvisa chi di dovere. Niente rimproveri, altrimenti la prossima volta non te lo dicono.

I canali oltre la mail

Canale	Come si presenta	Cosa chiedono
SMS	«pacco in giacenza», «il tuo SPID scade»	cliccare un link e inserire dati
Telefono	«sono della banca, c'è un'operazione sospetta»	il codice arrivato via SMS
QR code	su un volantino, un parcheggio, una finta multa	inquadrare e pagare o accedere
Messaggistica	«ciao, ho cambiato numero» da un finto collega o parente	un codice, un bonifico

Il meccanismo è sempre lo stesso: urgenza, un'autorità, una richiesta che da sola sembra piccola.

Chi può scrivere a nome della tua azienda: SPF, DKIM, DMARC

Metà del phishing finge di arrivare da un'azienda vera, a volte dalla tua. Tre impostazioni dicono al mondo chi è autorizzato a spedire mail a nome del tuo dominio: servono a far rifiutare ai destinatari le mail che si fingono te, e a dare al tuo filtro tre controlli in più su quelle che fingono gli altri. Sono tre righe di testo da mettere **una volta sola** nel DNS — l'elenco pubblico che traduce i nomi dei siti in indirizzi, e dove stanno anche questi record; lo si modifica dal pannello di chi ti gestisce il dominio.

Mettiamo che la tua azienda sia `tuazienda.it` e che la posta passi dal tuo fornitore (qui, per esempio, Google).

- **SPF, chi può spedire.** La riga elenca i server autorizzati. `v=spf1 include:_spf.google.com -all` vuol dire: «per noi spediscono solo i server di Google; chiunque altro, rifiutalo». Comincia sempre con `v=spf1` e finisce con `-all` (rifiuta) oppure `~all` (lascia passare, ma segnala).
- **DKIM, la firma.** Il server di posta mette su ogni messaggio in uscita una firma invisibile; chi riceve la verifica con una chiave che pubblichi anche quella nel DNS. Se qualcuno altera il messaggio, o non ha la chiave, la firma non torna. La chiave non si scrive a mano: te la dà il fornitore di posta, tu la incolli.
- **DMARC, cosa fare se falliscono.** La riga, messa su `_dmarc.tuazienda.it`, dice al destinatario come trattare le mail a nome tuo che non passano né SPF né DKIM, e dove mandarti un riepilogo. `v=DMARC1; p=quarantine; rua=mailto:postmaster@tuazienda.it` vuol dire: «se una mail a nome nostro non torna, mettila in quarantena, e mandami il resoconto». La parte che conta è `p=`: parti da `p=none`, che per un

paio di settimane osserva senza bloccare niente; quando i resoconti sono puliti, passa a `quarantine` e infine a `reject`.

In breve: SPF dice chi spedisce, DKIM firma, DMARC decide cosa fare quando i primi due non tornano e te lo racconta. Con tutti e tre attivi è molto più difficile che qualcuno spedisca una mail credibile a nome della tua azienda.

Controllare i tuoi, in dieci minuti. Averli scritti non basta: va verificato che siano giusti e che funzionino davvero sulle mail vere. Due modi, dal più semplice:

- **La prova sul campo.** Manda una mail dalla tua azienda a una casella Gmail (una qualsiasi che controlli). Aprila e scegli «Mostra originale»: in cima trovi tre righe — `SPF`, `DKIM`, `DMARC` — ciascuna con `PASS` o `FAIL`. Tre PASS vuol dire che i record ci sono e tornano su una mail spedita per davvero, non solo che esistono nel DNS.
- **Guardare i record a mano.** Dal prompt dei comandi: `nslookup -type=txt tuazienda.it` mostra l'SPF (la riga `v=spf1`), e `nslookup -type=txt _dmarc.tuazienda.it` mostra il DMARC. Il DKIM sta su un nome che dipende dal «selettore» scelto dal fornitore: il selettore si legge nell'intestazione di una mail già spedita (il campo `s=` dentro la firma DKIM), poi si interroga `nslookup -type=txt selettore._domainkey.tuazienda.it`.

Ci sono anche siti gratuiti che analizzano i tre record se dai loro il nome del dominio (che è un'informazione pubblica). E una volta attivo il DMARC con `rua=`, i resoconti che ti arrivano sono la verifica che continua da sola nel tempo.

Gli errori che vedo più spesso

- **Troppe regole.** Dieci regole non se le ricorda nessuno. Una sì.
- **Nessun posto dove segnalare.** Se non si sa a chi dirlo, non lo dice nessuno, e il primo che se ne accorge sei tu quando è tardi.
- **Dare la colpa a chi ha cliccato.** La mail era fatta per essere cliccata, e chi ha cliccato era stanco, o intimorito, o voleva aiutare. Chi si sente colpevole la prossima volta non lo dice, e tu lo scopri quando è tardi.
- **Il corso una volta l'anno.** Serve più un esempio vero mostrato in riunione ogni tanto che un corso di due ore a gennaio.

CON L'AI, PER QUESTA LEZIONE

Uso 5 di 12 · Due usi: preparare i colleghi, e smascherare i mittenti falsi. Primo, l'assistente ti prepara il materiale per la formazione in un pomeriggio. Secondo, ti costruisce un controllo veloce che riconosce i domini-trappola prima che ci caschi qualcuno. In nessuno dei due inventa niente: gli dai tu la lista di chi ti scrive davvero e quello che vedi arrivare.

A · Il materiale per i colleghi, fatto in un pomeriggio. La formazione sul phishing di solito non si fa perché non c'è tempo di prepararla. Con l'assistente il materiale lo prepari in un pomeriggio, e lo adatti alla tua azienda invece di comprare un corso generico.

> `Prepara per un'azienda di [N] persone del settore [settore] tre cose: una pagina A4 su come riconoscere un messaggio di phishing (quattro segnali, una sola regola: nessuno chiede mai password o codici); un quiz di dieci domande con tre risposte ciascuna, con esempi presi dal nostro lavoro (fornitori, corrieri, banca, buste paga); e una scaletta di quindici minuti per presentarlo in riunione. Tono semplice, niente termini tecnici.`

Prima di usarlo, leggi il quiz: qualche esempio non starà in piedi nel tuo settore, e lo cambi. Il numero da tenere d'occhio dopo non è quanti sbagliano il quiz, ma quanti cominciano a segnalare i messaggi sospetti.

B · Smascherare i mittenti falsi. Il trucco della mail dell'esempio — `fornitore-srl.com` al posto di `fornitore.com` — si smaschera in un attimo se hai sottomano l'elenco dei domini veri di chi ti scrive davvero. Prepara due colonne: i tuoi clienti e fornitori abituali, e per ciascuno il dominio di posta legittimo, quello che vedi nelle mail vere, nelle fatture, sul loro sito. È la tua lista bianca, e la scrivi una volta sola.

> `Questa è la lista dei nostri clienti e fornitori con il loro dominio di posta vero: [incolla le due colonne]. È arrivata una mail dal mittente [dominio del mittente]. Dimmi se corrisponde esatto a uno dei domini della lista, se è una sua imitazione (una lettera cambiata, un trattino in più, un'estensione diversa – .com al posto di .it), oppure un dominio che non c'entra niente. Se è un'imitazione, evidenziami la differenza carattere per carattere.`

Se ti serve sistematico, chiedigli lo script che faccia lo stesso su tutta la rubrica: confronti ogni mittente con la lista bianca e segnali quelli che somigliano ma non combaciano.

Il controllo a mano serve per i casi dubbi; il grosso lo deve fermare un filtro antispam, da solo. Non serve comprarlo: di filtri validi ne esistono anche gratuiti e open source — i più diffusi sono SpamAssassin e rspamd — e quasi sempre uno è già sul server di posta, acceso solo a metà. Tre cose che valgono la mezz'ora:

- **Accendi i controlli sul mittente.** Un filtro serio sa già verificare SPF, DKIM e DMARC (li trovi spiegati qui sopra): fai sì che una mail che li fallisce prenda punti di spam.
- **Alza il punteggio per i domini-trappola.** Una regola che aggiunga punti quando il mittente somiglia a un tuo dominio ma non è il tuo — la stessa lista bianca di prima — prende proprio il caso dell'esempio.

- **Quarantena, non cestino.** Manda i messaggi sospetti in una cartella a parte, non cancellarli: un filtro sbaglia sempre qualche volta, e una fattura vera persa fa più danno di una finta vista. La prima settimana guarda la quarantena una volta al giorno, poi quando serve.

DA FARE

Lunedì mattina, se sei l'unico informatico

1. Dai ai colleghi una regola sola, che si ricordano: nessuno chiede mai password o codici per mail, telefono o messaggio. Nemmeno tu. ☐
2. Crea un indirizzo o un canale dove inoltrare i messaggi sospetti, e rispondi sempre a chi lo usa, anche quando era un falso allarme. ☐
3. Alla prossima riunione fai vedere un esempio vero arrivato in azienda. Funziona più di un corso. ☐

Glossario

Le sigle nuove di questa lezione, con due righe ciascuna: la prima per capirsi, la seconda per capire. Poi, in breve, quelle delle lezioni precedenti.

SMS NUOVA — I messaggi di testo del telefono (Short Message Service). *Per capirla meglio:* Lo «smishing» è il phishing via SMS: pacco in giacenza, SPID in scadenza, multa da pagare. Gli SMS non hanno nessun controllo sul mittente, che si può scrivere a piacere, e i link accorciati nascondono la destinazione. Vale anche come secondo fattore debole: il codice via SMS si può dirottare.

QR NUOVA — Il quadrato a punti che si inquadra con il telefono per aprire un indirizzo (Quick Response code). *Per capirla meglio:* Il «quishing» è il phishing con un QR: un adesivo sul parcometro, un volantino, un QR dentro un PDF allegato. Il telefono apre l'indirizzo senza che si veda dove porta. Prima di inserire dati dopo un QR, si guarda l'indirizzo nella barra del browser.

OTP NUOVA — Il codice usa e getta che arriva per SMS o che genera un'app, da inserire oltre alla password (One-Time Password). *Per capirla meglio:* È il secondo fattore più comune. È anche quello che le truffe al telefono chiedono: «mi detti il codice che le è arrivato». Chi lo chiede sta usando la tua password in quel momento. Non si detta mai, a nessuno.

SPID NUOVA — L'identità digitale pubblica italiana, quella con cui si entra nei servizi della pubblica amministrazione (Sistema Pubblico di Identità Digitale). *Per capirla meglio:* Compare nel phishing perché è credibile e urgente («il tuo SPID scade»). I gestori SPID non chiedono mai credenziali per SMS o mail. Se un messaggio sullo SPID chiede di cliccare, è falso.

SPF NUOVA — Il record che dichiara quali server possono spedire mail a nome del tuo dominio (Sender Policy Framework). *Per capirla meglio:* È una riga nel DNS che comincia con `v=spf1` e finisce con `-all` (rifiuta chi non è in elenco) o `~all` (lascia passare ma segnala). Da sola non basta: va insieme a DKIM e DMARC.

DKIM NUOVA — La firma che il server mette sulle mail in uscita, così chi le riceve verifica che siano davvero tue e non alterate (DomainKeys Identified Mail). *Per capirla meglio:* La chiave per verificarla si pubblica nel DNS; la genera il fornitore di posta, non si scrive a mano.

DMARC NUOVA — La regola che dice ai destinatari cosa fare con le mail a nome tuo che non passano SPF o DKIM, e dove mandarti i resoconti (Domain-based Message Authentication, Reporting and Conformance). *Per capirla meglio:* La parte che conta è `p=` : si parte da `none` per osservare, poi `quarantine` , poi `reject` .

Dalle lezioni precedenti (la spiegazione completa è nella lezione in cui sono comparse):

CIA — Le tre cose da proteggere: riservatezza, integrità, disponibilità (in inglese Confidentiality, Integrity, Availability). Niente a che vedere con l'agenzia americana. *(lezione 1)*

ransomware — Un programma che cifra i file dell'azienda e chiede un riscatto per la chiave. Non è una sigla, ma è la parola che torna più spesso. *(lezione 1)*

DDoS — Attacco che manda a un servizio più richieste di quante ne regga, finché smette di rispondere. Sta per Distributed Denial of Service. *(lezione 1)*

HTTPS — La versione cifrata di HTTP, il protocollo delle pagine web. È il lucchetto nel browser. *(lezione 1)*

PLC — Il computer industriale che comanda una macchina o una linea di produzione (Programmable Logic Controller). *(lezione 1)*

IBAN — Il codice del conto corrente, quello che si scrive per fare un bonifico (International Bank Account Number). *(lezione 1)*

AI — Intelligenza artificiale. Qui vuol dire gli assistenti con cui si parla scrivendo, e i modelli che ci stanno dietro. *(lezione 1)*

CVE — Il codice univoco di una vulnerabilità nota, nel formato CVE-anno-numero (Common Vulnerabilities and Exposures). *(lezione 2)*

CWE — La categoria di una debolezza del software, per esempio «SQL injection» (Common Weakness Enumeration). *(lezione 2)*

CVSS — Il punteggio di gravità di una vulnerabilità, da 0 a 10 (Common Vulnerability Scoring System). *(lezione 2)*

NVD — La banca dati pubblica dei CVE, gestita dal NIST americano (National Vulnerability Database). *(lezione 2)*

NIST — L'ente americano degli standard (National Institute of Standards and Technology). Gestisce l'NVD e pubblica le linee guida più usate. *(lezione 2)*

CNA — Gli enti autorizzati ad assegnare i codici CVE: grandi produttori, CERT nazionali, ricercatori accreditati (CVE Numbering Authority). *(lezione 2)*

MITRE — L'organizzazione americana senza scopo di lucro che coordina i CVE e gestisce ATT&CK. *(lezione 2)*

CERT — Una squadra che risponde agli incidenti informatici, nazionale o di settore (Computer Emergency Response Team). *(lezione 2)*

EPSS — Una stima, in percentuale, della probabilità che una vulnerabilità venga sfruttata nei prossimi trenta giorni (Exploit Prediction Scoring System). *(lezione 2)*

AV, AC, PR, UI — Le quattro lettere principali del vettore CVSS: da dove si attacca, quanto è difficile, se servono privilegi, se serve un'azione dell'utente. *(lezione 2)*

SQL — Il linguaggio con cui si interrogano le banche dati (Structured Query Language). *(lezione 2)*

XSS — Un difetto di un sito che permette di far eseguire del codice nel browser di chi lo visita (Cross-Site Scripting). *(lezione 2)*

VPN — Un collegamento cifrato da fuori verso la rete aziendale, come se si fosse in ufficio (Virtual Private Network). *(lezione 2)*

NAS — Un disco di rete condiviso, spesso usato per i file e per i backup (Network Attached Storage). *(lezione 2)*

API — Un modo per far parlare due programmi fra loro, senza passare da una pagina web (Application Programming Interface). *(lezione 2)*

KEV — Il catalogo delle vulnerabilità che vengono già sfruttate in attacchi reali, tenuto da CISA (Known Exploited Vulnerabilities). *(lezione 3)*

CISA — L'agenzia americana per la sicurezza informatica e delle infrastrutture (Cybersecurity and Infrastructure Security Agency). *(lezione 3)*

FIRST — L'associazione mondiale delle squadre di risposta agli incidenti, che calcola e pubblica l'EPSS (Forum of Incident Response and Security Teams). *(lezione 3)*

CSV — Un file di testo con i dati in colonne separate da virgole (Comma-Separated Values). Si apre con un foglio di calcolo. *(lezione 3)*

ATT&CK — Il catalogo, tenuto da MITRE, delle tattiche e tecniche che gli attaccanti usano davvero. *(lezione 4)*

TA0004, T1053 — I codici delle tattiche (TA) e delle tecniche (T) nel catalogo ATT&CK. *(lezione 4)*

C2 — Il canale con cui chi attacca comanda da remoto un computer infetto (Command and Control). *(lezione 4)*

OWASP — Una comunità mondiale che pubblica materiale gratuito sulla sicurezza delle applicazioni web (Open Web Application Security Project). *(lezione 4)*

USB — La presa a cui si attaccano chiavette, mouse, tastiere (Universal Serial Bus). *(lezione 4)*

Ing. Alessandro Manneschi
Cyber Security Architect · NIS2, monitoraggio e sicurezza per le PMI

Tutte le lezioni, gratis:
github.com/alevento/sicurezza-per-chi-e-solo
Licenza CC BY-NC-SA 4.0